

Checklist de segurança - GitHub

O que VOCE precisa alterar (conta, repos, Cloudflare e PC)

Perfil: @joaoabitante | Repo: premioelisaofiscal | Data: 10/07/2026

Ja corrigido no codigo (v1.5.2 no GitHub)

- [x] .gitignore reforçado (.env, chaves, .claude/, .cursor/, .grok/)
- [x] Pasta .claude/ removida do versionamento
- [x] SECURITY.md com canal de reporte
- [x] Checklist em docs/CHECKLIST-SEGURANCA-GITHUB.md

FACA PRIMEIRO (15 minutos) se estiver cansado

- [] 1. Ativar 2FA no GitHub
- [] 2. Fechar as 2 PRs do bot Cloudflare (se o deploy ja funciona)
- [] 3. Bloquear force push na branch main
- [] 4. Configurar e-mail noreply no git config
- [] 5. Ativar Secret scanning + Push protection

1. Conta GitHub - autenticacao (critico - 5 min)

<https://github.com/settings/security>
<https://github.com/settings/sessions>

- [] Ativar 2FA (Authenticator app - melhor que SMS)
- [] Salvar codigos de recuperacao offline (papel/cofre), NAO no OneDrive do projeto
- [] Em Sessions: encerrar sessoes que voce nao reconhece

2. E-mail nos commits - privacidade (5 min)

<https://github.com/settings/emails>

- [] GitHub > Settings > Emails > Keep my email addresses private
- [] Marcar: Block command line pushes that expose my email
- [] Copiar o endereco noreply (NUMERO+joaoabitante@users.noreply.github.com)
- [] No PC: git config --global user.email "COLE_O_NOREPLY"
- [] git config --global user.name "Joao Abitante"
- [] Confirmar: git config --global --get user.email
- [] Proximo commit no GitHub ja sem Gmail real

Nao reescreva o historico antigo so por e-mail. Foque nos commits novos.

3. Tokens, SSH e apps (critico - 10 min)

<https://github.com/settings/keys>
<https://github.com/settings/tokens>
<https://github.com/settings/installations>
<https://github.com/joaoabitante/premioelisaofiscal/pull/1>
<https://github.com/joaoabitante/premioelisaofiscal/pull/2>

- [] Revisar SSH keys: so as que voce reconhece; apagar as outras
- [] Revogar PATs antigos/sem uso (preferir fine-grained + expiracao curta)
- [] NUNCA colar token em chat, issue, commit ou OneDrive do projeto
- [] Revisar app Cloudflare Workers and Pages (so repos de deploy)
- [] Remover apps GitHub que voce nao usa
- [] PR #1 e #2 do bot Cloudflare: ler o diff
- [] Se o site ja publica com push na main: Close PR sem merge

- ☐ So mergear se quiser wrangler.jsonc e souber que nao quebra o deploy
- ☐ Cloudflare: Web Analytics, RUM, Workers Logs/Logpush DESLIGADOS

4. Protecao da branch main (alto - 5 min)

<https://github.com/joaoabitante/premioelisaofiscal/settings/branches>

- ☐ Add branch protection rule com nome: main
- ☐ Restrict force pushes (bloquear force push)
- ☐ Restrict deletions
- ☐ Do not allow bypassing (se disponivel no plano)
- ☐ Opcional: exigir PR antes de merge (pode atrapalhar fluxo solo)
- ☐ Repetir em outros repos com deploy automatico

5. Code security do repositorio (medio - 5 min)

https://github.com/joaoabitante/premioelisaofiscal/settings/security_analysis

https://github.com/settings/security_analysis

- ☐ Dependency graph - Enable
- ☐ Dependabot alerts - Enable
- ☐ Secret scanning - Enable
- ☐ Push protection (secret scanning) - Enable
- ☐ Private vulnerability reporting - Enable
- ☐ Alinhar defaults da conta para repos novos

6. Features que viram spam + repos (baixo - 3 min)

<https://github.com/joaoabitante?tab=repositories>

- ☐ Desligar Wiki em cada repo publico que nao usa
- ☐ premioelisaofiscal - Wiki off (permanece publico OSS)
- ☐ abitanteventures - Wiki off
- ☐ mundialTAX, copa2026, aprendasobrekyc, compliance, trucolegends - Wiki off
- ☐ CONFIRMAR: elisaofiscal esta PRIVATE (produto fiscal)

7. Perfil e identidade (opcional - 2 min)

<https://github.com/settings/profile>

- ☐ Decidir nome exibido: civil completo ou marca publica
- ☐ Bio / site apontando para elisaofiscal.net se quiser
- ☐ Repo Premio > Settings > Website = <https://premio.elisaofiscal.net>

8. Cloudflare deploy (5 min)

<https://dash.cloudflare.com>

<https://dash.cloudflare.com/profile/api-tokens>

- ☐ Projeto do Premio ligado SO ao repo premioelisaofiscal
- ☐ Deploy automatico na branch main
- ☐ Web Analytics OFF
- ☐ RUM OFF
- ☐ Workers Logs / Logpush OFF
- ☐ Revogar API tokens Cloudflare nao usados; nunca commitar token

9. PC / Git local (5 min)

- [] Credenciais: SSH ou Git Credential Manager (nao .git-credentials no OneDrive)
- [] Confirmar remote: so origin -> github.com/joaoabitante/premioelisaofiscal.git
- [] Se houver remote errado: git remote remove NOME
- [] Nunca git push --force em main de producao sem backup

O que NAO precisa fazer

- Reescrever historico git so para trocar e-mail antigo
- Adicionar dependencias de seguranca no Premio (nao ha backend com auth)
- Tornar o Premio privado (e open source de proposito)

Apos marcar as secoes 1 a 4, a higiene da conta fica alinhada a de um dev senior solo com deploy em producao.

Fonte: docs/CHECKLIST-SEGURANCA-GITHUB.md | SECURITY.md | github.com/joaoabitante/premioelisaofiscal